NASEEJ

Patient-owned health history and visit-preparation platform

Functional and Non-Functional Requirements

Software requirements specification

Project	Naseej, a patient-owned health history and visit-preparation app
Document	Functional and non-functional requirements
Version	1.1
Date	28 October 2026
Based on	Naseej-PRD.md (version 2.1), PRODUCT.md, SECURITY.md, docs/features/ (patient-record, accounts, notifications, pwa, translation), docs/reference/ (architecture, api-spec, database-erd), docs/guides/test-plan.md, database migrations 001 to 007
Status	Academic prototype. Synthetic data only.

Contents

1. Introduction . . . 3

1.1 Purpose . . . 3

1.2 Product summary . . . 3

1.3 Actors . . . 3

1.4 Out of scope . . . 3

1.5 Status values and summary . . . 3

2. Functional requirements . . . 4

2.1 Account and access . . . 4

2.2 Health profile and symptoms . . . 4

2.3 Timeline and search . . . 5

2.4 Document vault . . . 5

2.5 Visit preparation . . . 6

2.6 Assistant, safety and voice . . . 6

2.7 QR sharing and clinician access . . . 7

2.8 Translation of typed text . . . 7

2.9 Notifications, installation and interface language . . . 8

2.10 Audit . . . 8

2.11 Not provided (future) . . . 8

3. Non-functional requirements . . . 9

3.1 Security . . . 9

3.2 Privacy and data protection . . . 9

3.3 AI safety . . . 10

3.4 Reliability and availability of features . . . 10

3.5 Usability and accessibility . . . 10

3.6 Compatibility and portability . . . 11

3.7 Maintainability and testability . . . 11

4. Constraints and assumptions . . . 12

5. Traceability . . . 12

6. Known limitations and open points . . . 13

1. Introduction

1.1 Purpose

This document states what Naseej must do (functional requirements) and how well it must do it (non-functional requirements). Each requirement has an identifier, a statement, an acceptance criterion or measure, and its current status or verification, so that it can be designed, tested and traced.

1.2 Product summary

Naseej helps a patient organize their medical journey, explain symptoms clearly in a consultation, and securely share selected information with any doctor, clinic or hospital. It organizes and informs. It never diagnoses, prescribes treatment or changes a dose. Core loop: record, organize on a timeline, prepare a visit summary, review and approve, share by temporary QR code, and the clinician reads it read-only.

1.3 Actors

Actor	Account	Role in the system
Patient	Yes, the only signed-in role	Keeps the record, prepares visits, controls every share, optionally uses the assistant.
Clinician	No	Opens a share link on a phone and reads the approved summary and permitted documents, read-only.
AI provider (optional)	External	Anthropic or Gemini, used only with the patient's consent. Off unless configured.
Email service	External	SMTP server that delivers confirmation and password-reset messages.
Translation engine	Internal	Local glossary and machine-translation models. Not an AI assistant.

1.4 Out of scope

- Diagnosis, triage beyond one fixed emergency message, treatment or dose advice.
- Clinic and hospital management portals.
- Clinician accounts.
- Claims of compliance with any healthcare regulation.

1.5 Status values and summary

Implemented: built and covered by tests or by the manual plan. **Needs AI provider**: built, but needs an external AI provider that has not been run yet. **Needs clinical review**: built, but the wording must be approved by a clinician before real use. **Future**: not provided.

Group	Count
Functional requirements	62
Implemented	50
Needs AI provider	4
Needs clinical review	2
Future (not provided)	6
Non-functional requirements	29

2. Functional requirements

The system shall provide the behaviours below. Requirement identifiers are stable and are used in the traceability table in section 5.

2.1 Account and access

ID	Requirement	Acceptance criterion	Status
FR-1.1	The system shall let a person create a patient account with an email address, full name and password.	The password has at least 8 characters, contains a letter and a number, and is at most 72 bytes. A weaker password is rejected with an error code.	Implemented
FR-1.2	The system shall require the email address to be confirmed before the first sign-in.	A single-use link valid for 24 hours is mailed. Sign-in is refused with EMAIL_NOT_VERIFIED until the link is used. The link can be sent again.	Implemented
FR-1.3	The system shall let a user reset a forgotten password by email.	A single-use link valid for 1 hour is mailed. After a reset every other signed-in device is signed out and the owner receives a notice by email.	Implemented
FR-1.4	The system shall not reveal whether an email address already has an account.	Registration, resend and forgot-password answer 202 in the same way for known and unknown addresses.	Implemented
FR-1.5	The system shall let the patient sign in and sign out with email and password.	A valid login returns a session token. The session identifies the patient profile used to scope every later request.	Implemented
FR-1.6	The system shall let the patient manage account settings.	Profile, contact details, password, language, theme and the assistant switch can be changed and are saved.	Implemented
FR-1.7	The system shall send account email through a configured SMTP server and shall never claim that a message was sent when it was not.	With SMTP configured, mail is sent. In development the links are printed in the API console. In production without SMTP the API answers 503 EMAIL_NOT_CONFIGURED and the screen says email is not set up.	Implemented
FR-1.8	The system shall not invent profile fields.	National id, birth date, gender and phone are optional. Screens show "not recorded" or leave the row out.	Implemented

2.2 Health profile and symptoms

ID	Requirement	Acceptance criterion	Status
FR-2.1	The system shall let the patient keep health entries of these kinds: condition, medication, allergy, procedure, measurement and visit.	Create, correct, delete and restore work. An invalid kind, date or field is rejected.	Implemented
FR-2.2	Each health entry shall keep its date, source and review state.	The source is patient, assistant, document or clinician. The review state is confirmed or needs review. Both are shown on the entry.	Implemented
FR-2.3	The system shall let the patient record symptoms.	A symptom holds description, start, duration, frequency, severity, better and worse factors, notes and related documents. A future start date or a severity outside 1 to 10 is rejected.	Implemented
FR-2.4	The system shall record how each symptom was captured.	The capture channel is stored as form, assistant or voice.	Implemented
FR-2.5	Deleting a symptom or an entry shall be reversible.	A deleted item disappears from lists and the timeline and can be brought back with undo or restore.	Implemented

2.3 Timeline and search

ID	Requirement	Acceptance criterion	Status
FR-3.1	The system shall show a read-only timeline built from the patient's record.	Symptoms, patient-recorded visits, documents, document readings and clinician-approved records appear in date order. No create, update or delete operation exists for the timeline.	Implemented
FR-3.2	Each timeline event shall show where it came from.	An event shows its origin, certainty (clear, check, conflict or undated), confidence, source document, page and passage where available.	Implemented
FR-3.3	The timeline shall be filterable and pageable.	Filters by type, center and date; cursor paging; deleted items are hidden.	Implemented
FR-3.4	The system shall let the patient search their own record.	A plain search returns only items that belong to the signed-in patient.	Implemented

2.4 Document vault

ID	Requirement	Acceptance criterion	Status
FR-4.1	The system shall let the patient upload a PDF, PNG or JPEG file up to 4 MB, or take a photo.	The file type is checked from the bytes, not the name. Phone photos are downscaled in the browser. Any other type, or a larger file, is refused.	Implemented
FR-4.2	The system shall store a type, date and provider for each document and let the patient edit them and link the document.	A document can be linked to a symptom, entry or visit of the same patient only.	Implemented
FR-4.3	The system shall let the patient list, search and filter documents and always retrieve the original file.	The original is downloadable through an authorized route at any time.	Implemented
FR-4.4	The system shall move deleted documents to a trash from which they can be restored.	A trashed document leaves lists and can be restored.	Implemented
FR-4.5	Vault documents shall belong to the patient only.	A vault document has no center and is invisible to every center and clinician. A clinician can reach it only through a share created by the patient.	Implemented
FR-4.6	The system shall show the processing state of a document reading.	The states processing, failed and retry are visible to the patient.	Implemented
FR-4.7	The system shall offer optional AI reading of a document.	Reading starts only after the patient confirms that file. Results appear as unconfirmed suggestions with page and passage. With no provider configured the feature says it is off.	**Needs AI provider**
FR-4.8	A suggestion shall become a health entry only when the patient confirms it.	Each suggestion can be confirmed or dismissed once. Confirm creates an entry with source document and review state confirmed. Dismiss marks it rejected.	Implemented

2.5 Visit preparation

ID	Requirement	Acceptance criterion	Status
FR-5.1	The system shall build a visit summary draft from the patient's record or from chosen timeline events.	The patient may choose a visit date or none. The draft is built by code, not by a language model.	Implemented
FR-5.2	Every item in a visit summary shall carry a verifiable source.	Each source reference is checked to belong to the patient. A forged reference is rejected.	Implemented
FR-5.3	The system shall let the patient edit the draft.	Items taken from the record keep their text and can be removed but not rewritten. Sections can be removed. The patient can add own questions.	Implemented
FR-5.4	The system shall let the patient select which documents go with the summary.	Only selected documents are attached to the summary.	Implemented
FR-5.5	A visit summary shall be approved by the patient before it can be shared.	Approval needs explicit confirmation. Editing an approved summary returns it to draft. Creating a share from a draft is refused.	Implemented
FR-5.6	The system shall let the patient preview and print a summary.	The preview shows exactly the approved content.	Implemented
FR-5.7	The system shall offer optional overview wording proposed by a language model.	The overview restates only listed items, is shown to the patient to accept or discard, and is rejected if it cites nothing or is unsafe.	**Needs AI provider**

2.6 Assistant, safety and voice

ID	Requirement	Acceptance criterion	Status
FR-6.1	The assistant shall stay off until the patient switches it on and shall say so when it is unavailable.	With no provider the assistant says it is not connected. Record search, guided symptom capture, summary drafting and sharing still work.	Implemented
FR-6.2	Assistant answers about the record shall be grounded and cited.	An answer cites sources from the record or says "not recorded". A citation that is not in the record list is dropped. An answer with no valid citation becomes "not found".	**Needs AI provider**
FR-6.3	The assistant shall never change the record.	It has no write tools. A symptom it proposes is a draft that the patient reviews and saves. Navigation requests use a whitelist.	**Needs AI provider**
FR-6.4	The system shall guide symptom capture one question at a time.	The flow works without an AI provider and ends in a draft that the patient reviews before saving.	Implemented
FR-6.5	Emergency wording and requests for diagnosis, treatment or a dose change shall receive fixed answers before any model is called.	The check runs on the server, also on symptom form text, and returns fixed Arabic or English text.	**Needs clinical review**
FR-6.6	A model reply that advises, diagnoses or changes a dose shall be replaced by a fixed refusal.	Unsafe output never reaches the patient.	**Needs clinical review**
FR-6.7	The assistant context shall be minimal.	Only a short text summary of the record is sent to a provider. It holds no name, national id or contact details.	Implemented
FR-6.8	The system shall support voice dictation into editable fields.	Dictation fills a field the patient can edit. Numbers, dates and doses are shown for checking before saving. Typing is always a full alternative, and unsupported browsers fall back to typing.	Implemented

2.7 QR sharing and clinician access

ID	Requirement	Acceptance criterion	Status
FR-7.1	The system shall let the patient create a temporary share of an approved summary.	A share needs an approved summary and an explicit confirmation after a preview.	Implemented
FR-7.2	The patient shall control what a share contains and how long it lasts.	The patient picks the documents, identity on or off, and a duration from 1 hour up to SHARE_MAX_HOURS. The preview equals what the clinician will see.	Implemented
FR-7.3	The share link shall be shown once as a QR code and a link.	The token is not recoverable afterwards. To share again the patient revokes and creates a new share.	Implemented
FR-7.4	A share shall hold a frozen copy of what the patient approved.	Later edits to the record or the summary never change an existing share.	Implemented
FR-7.5	The clinician shall read the share on a page that needs no account.	The page is read-only and printable, shows only approved content, opens a document only if it was granted, and has states for invalid, expired, revoked, offline and rate-limited.	Implemented
FR-7.6	Revocation and expiry shall take effect immediately.	The next request to an expired or revoked share answers 410. Deleting a document removes it from shares at once.	Implemented
FR-7.7	The frozen copy of an ended share shall be erased.	The copy is erased one day after the link expires or is revoked.	Implemented
FR-7.8	The patient shall see an access history for each share.	Each view, document open and denied attempt is listed with time and device class. No address and no content is shown.	Implemented
FR-7.9	The patient shall be able to list shares and see their status.	Shares appear as active, expired or revoked.	Implemented

2.8 Translation of typed text

ID	Requirement	Acceptance criterion	Status
FR-8.1	Text typed by a person shall be shown in the language of the page.	Each text is shown as written, translated with a label and a Show original control, or unavailable with the original and a note. The stored original is never changed.	Implemented
FR-8.2	Translation shall not use an AI assistant or an external service.	A local glossary and local machine translation are used. A result is accepted only if its numbers survive and a round-trip check passes. The same wording is translated once and reused.	Implemented
FR-8.3	The clinician page shall translate only wording that is inside the share.	A request for text outside the share is refused with not_allowed.	Implemented

2.9 Notifications, installation and interface language

ID	Requirement	Acceptance criterion	Status
FR-9.1	The system shall show in-app notifications to the signed-in patient.	The server creates them after the operation succeeded. The patient can read, dismiss, restore and read all. Each has a typed destination inside the app. Current event: password changed.	Implemented
FR-9.2	The application shall be installable and shall protect private data offline.	An install action or manual steps are offered. An update banner appears when a new version exists. Offline, only the interface shell opens and a notice says that data needs a connection. /api responses are never cached.	Implemented
FR-9.3	The interface shall be available in Arabic (right to left) and English (left to right).	Switching language does not reset a form. A light and a dark theme are available.	Implemented

2.10 Audit

ID	Requirement	Acceptance criterion	Status
FR-10.1	The system shall log security-relevant actions.	Create, update, delete and restore, approvals, AI consent, and share creation and revocation are logged with ids and kinds only, never health content.	Implemented

2.11 Not provided (future)

ID	Requirement	Acceptance criterion	Status
FR-F1	Email or push reminders.	Not provided.	**Future**
FR-F2	Server-side speech transcription.	Not provided. Dictation depends on the browser.	**Future**
FR-F3	FHIR import and export.	Not provided.	**Future**
FR-F4	Clinician accounts.	Not provided. Clinicians read shares without an account.	**Future**
FR-F5	External identity provider sign-in.	Not provided.	**Future**
FR-F6	Account deletion path and privacy notice.	Not provided. Required before real people use the system.	**Future**

3. Non-functional requirements

The system shall meet the quality attributes below. The verification column names the test file or the review that evidences each one. No numeric response-time or capacity target has been defined; see section 6.

3.1 Security

ID	Requirement	Measure or acceptance	Verification
NFR-1.1	Ownership isolation. Every private query shall be filtered by the session's patient profile.	A row of another patient answers 404, never 403. Other roles answer 403 PATIENT_PROFILE_REQUIRED.	patient-owned-record.test.ts
NFR-1.2	Share tokens shall be unguessable and never stored in clear.	256 random bits. Only the SHA-256 is stored. The token travels in the URL fragment, which is not sent to a server.	patient-owned-record.test.ts, health-units.test.ts
NFR-1.3	Public share endpoints shall resist abuse and leakage.	60 requests per minute per address and 10 unknown-token attempts per 10 minutes. Responses are no-store, no-referrer and noindex.	Automated tests, docs/features/patient-record.md
NFR-1.4	Credentials and account links shall be protected.	Passwords are stored as hashes. Account links are 256-bit single-use tokens stored as SHA-256. Rate limits apply per address and per client on every account endpoint.	auth.test.ts, access.test.ts, docs/features/accounts.md
NFR-1.5	Uploaded files shall not be reachable directly.	Files are stored under random UUID names outside the web root and are served only through authorized routes. A share streams only the documents granted to it.	patient-owned-record.test.ts
NFR-1.6	Secrets shall stay out of the code base.	API keys and SMTP credentials live in .env and are never committed.	Review, SECURITY.md

3.2 Privacy and data protection

ID	Requirement	Measure or acceptance	Verification
NFR-2.1	Data minimization towards AI providers.	No name, national id or contact detail is sent. Nothing is sent before the patient's switch and, for documents, per-file confirmation.	health-units.test.ts
NFR-2.2	The assistant conversation shall not be stored.	Conversation text is held in browser memory only. The interaction log keeps metadata: kind, outcome, provider, model and latency.	patient-owned-record.test.ts
NFR-2.3	The audit log shall hold no health content.	Entries carry ids and kinds only.	patient-owned-record.test.ts
NFR-2.4	The browser shall keep no health data from the patient screens.	No health data in local storage or IndexedDB. The service worker never caches /api.	Review, docs/features/pwa.md
NFR-2.5	Data shall not be kept longer than needed.	The frozen copy of an ended share is erased after 1 day. Unused translations are pruned after 90 days. Notifications expire after 90 days.	docs/features/patient-record.md, docs/features/translation.md
NFR-2.6	The prototype shall use synthetic data only.	Real patient data is forbidden until the deployment work in section 6 is done.	Project policy, SECURITY.md

3.3 AI safety

ID	Requirement	Measure or acceptance	Verification
NFR-3.1	Safety rules shall run on the server.	Instructions, safety rules and permissions are not in the browser.	health-units.test.ts
NFR-3.2	The assistant shall have no tools.	It returns one structured reply. The server validates it and replaces unsafe output.	health-units.test.ts
NFR-3.3	Suggestions shall never silently become facts.	AI readings and drafts stay visibly unconfirmed until the patient confirms.	patient-owned-record.test.ts
NFR-3.4	Anything written, created or shared on the patient's behalf shall need explicit confirmation.	Record writes, QR creation and sharing each require a patient action.	patient-owned-record.test.ts

3.4 Reliability and availability of features

ID	Requirement	Measure or acceptance	Verification
NFR-4.1	AI calls shall be bounded.	A timeout (AI_CHAT_TIMEOUT_MS) and an hourly limit (ASSISTANT_MAX_PER_HOUR) apply. Errors are shown with a retry.	Automated tests, manual plan
NFR-4.2	Features shall degrade honestly.	A feature that is off says so. Everything that does not need a provider keeps working without one.	Manual plan
NFR-4.3	A notification problem shall never fail the operation that caused it.	The error is logged and the operation completes.	Design review, docs/features/notifications.md
NFR-4.4	Database changes shall be additive and reversible.	Each migration has a rollback. The CI job migrates an empty database, re-runs migrations as a no-op, then rolls back and re-applies.	CI database job

3.5 Usability and accessibility

ID	Requirement	Measure or acceptance	Verification
NFR-5.1	The interface shall be mobile first.	No horizontal overflow at a width of 375 px.	Manual plan
NFR-5.2	Arabic shall be the native experience.	Full right-to-left layout. The English text tree has exactly the same keys as the Arabic one.	frontend/tests/i18n.test.ts
NFR-5.3	The interface shall be easy to read and operate.	Visible focus, large touch targets, state never shown by color alone, short forms and calm wording.	Manual plan
NFR-5.4	Missing information shall be shown honestly.	An absent record reads "not recorded", never "absent".	Design review

3.6 Compatibility and portability

ID	Requirement	Measure or acceptance	Verification
NFR-6.1	Providers shall be replaceable.	AI, document analysis and translation sit behind interfaces chosen by environment variables. The AI provider is Anthropic or Gemini, or none.	ai-providers.test.ts
NFR-6.2	The application shall run in current desktop and mobile browsers.	Voice dictation needs a browser with speech recognition. Installation needs HTTPS, and localhost counts as secure.	Manual plan
NFR-6.3	The application shall run locally from the repository.	React with Vite, Node.js with Express, and PostgreSQL, set up with the documented npm scripts.	README.md

3.7 Maintainability and testability

ID	Requirement	Measure or acceptance	Verification
NFR-7.1	The system shall have automated tests for its rules.	Vitest unit tests and Supertest API tests against a real database, for ownership, shares, accounts, timeline conflicts and translation. The AI is forced off in tests.	backend/tests, frontend/tests, docs/guides/test-plan.md
NFR-7.2	Strings shall be typed against the Arabic source.	A missing translation key fails the build or the test.	frontend/tests/i18n.test.ts

4. Constraints and assumptions

- **Data.** The prototype uses synthetic data only. Real patient data is forbidden.
- **Technology.** React 19 with Vite and TypeScript on the front end, Node.js with Express 5 on the back end, PostgreSQL with SQL migrations 001 to 007.
- **Optional services.** The AI provider is optional and may be unavailable. Email needs an SMTP account supplied by the team.
- **Browsers.** Voice dictation depends on the browser. Installation needs HTTPS (localhost counts as secure).
- **Limits.** Upload size 4 MB. Share duration from 1 hour up to SHARE_MAX_HOURS.
- **Regulation.** The system makes no claim of compliance with any healthcare regulation.
- **Users.** Patients are assumed to have varying digital and health literacy, so the interface favours short, calm language and large touch targets.

5. Traceability

Each group of functional requirements is linked to its use cases, main data tables and API area, and to the numbering of the product requirements document (PRD).

Requirement group	Use case	Main tables	API area	PRD ref
Account and access	Create account / sign in	users, auth_tokens	/api/auth/*	FR-15
Health profile and symptoms	Manage health profile; Record and review symptoms	health_entries, symptom_reports	/api/record/entries, /api/record/symptoms	FR-01, FR-02
Timeline and search	View health timeline	(derived from other tables)	/api/record/events, /api/record/search	FR-03
Document vault	Upload and manage documents; Review document suggestions	documents, document_links, document_facts	/api/vault/documents	FR-04, FR-05
Visit preparation	Prepare and approve visit summary	visit_preps	/api/prep	FR-06, FR-07
Assistant, safety, voice	Ask assistant about own record	ai_interactions, patient_profiles	/api/assistant/*	FR-08, FR-09, FR-10
QR sharing	Create temporary QR share; Revoke share and inspect access history; Read approved shared summary; Open permitted shared document	record_shares, share_documents, share_access_events	/api/shares, /api/share-view/*	FR-11 to FR-14
Translation of typed text	(supports all screens)	content_translations	/api/translations	FR-17
Notifications, install, language	(supports all screens)	notifications	/api/notifications	FR-16
Audit	(supports all use cases)	audit_logs	(internal)	NFR-03
Not provided (future)	-	-	-	FR-18

6. Known limitations and open points

- No live AI provider has been run yet; the AI-dependent requirements are implemented and tested with stubs only.
- The safety wording and keyword lists are engineering defaults. A clinician must review them before real use (FR-6.5, FR-6.6).
- Rate limits are held in memory per process. Several instances need a shared store.
- Files are stored unencrypted on local disk, and trashed documents are not purged automatically.
- Voice dictation depends on the browser, and Chrome and Edge send audio to the vendor.
- No numeric performance targets (response time, capacity) have been defined yet. They are to be agreed with the supervisor.
- No usability study, screen-reader audit or test on physical devices has been run yet.
- Email sign-up stores real addresses and names. A privacy notice, an account-deletion path and a review of server logs are needed before real people use it (FR-F6).